Unit-3 Public key Cryptography

3.1 Public-Key Cryptography : Principles of public-key cryptosystems, Applications of Public-key cryptosystems

❖ Public-Key Cryptography(PKC)

- ✓ PKC stands for Public Key Cryptography. It is also known as **asymmetric cryptography**.
- ✓ It is an encryption technique or a framework that uses a pair of keys (public and private key) for secure data communication.
- ✓ These keys are related, but not identical keys. Each key performs a unique function, i.e., the public key is used to encrypt, and the private key is used to decrypt.
- ✓ The sender uses the receiver's public key to encrypt a message, and the receiver uses the private key to decrypt this message.
- ✓ PKC is different from the symmetric key algorithm, which uses only one key to both encrypt and decrypt.
- ✓ The two types of PKC algorithms are RSA (Rivest, Shamir, and Adelman) and Digital Signature Algorithm (DSA).
- ✓ The Public key algorithm operates in the following manner:

❖ Principles of public-key cryptosystems

Plaintext: This is the readable message or data that is fed into the algorithm as input.

Encryption algorithm: The encryption algorithm performs various transformations on the plaintext.
Public and private keys: This is a pair of keys that have been selected so that if one is used for encryption, the other is used for decryption. The exact transformations performed by the algorithm depend on the public or private key that is provided as input.

Cipher text: This is the scrambled message produced as output. It depends on the plaintext and the key. For a given message, two different keys will produce two different cipher texts.

Decryption algorithm: This algorithm accepts the cipher text and the matching key and produces the original plaintext.

❖ Applications of public-key cryptosystems

✓ The main applications of Public key cryptosystem are **Digital Signatures and Data Encryption**.
✓ **Digital signatures** are the public-key primitives of message authentication. The digital signature generated by the private key of a user and hash algorithm. First the message is encrypted by the private key of the user. The encrypted message creates a signature for user after using the hash algorithm on it.
✓ **The encryption application**: It can transform the plaintext into unreadable format, and it can be used to connect message securely to receiver. It supports the confidentiality and integrity security services for the information. The public key supports the security services including authentication and non-repudiation.

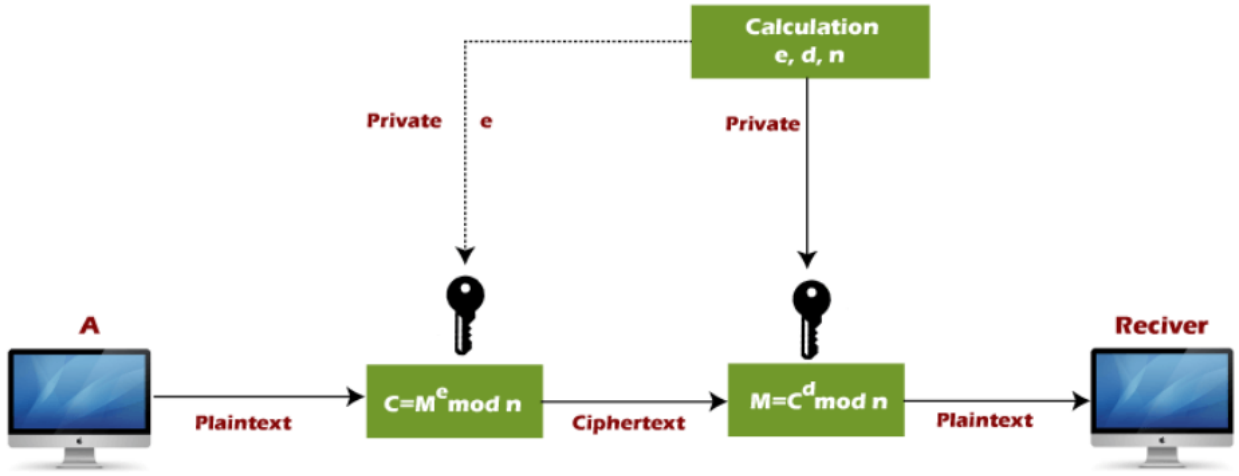
VPMP POLYTECHNIC

✓ **Key generation** – each user generates two keys including public key and private key. The private key maintains at user side and public key is freely accessible in the network.

✓ Emails can be encrypted using public-key cryptography to keep their content confidential
✓ Secure socket layer (SSL) protocol also uses asymmetric cryptography to make secure connections to websites
✓ It is also used in block chain and cryptography technology. For example, while setting up a new crypto currency wallet, a pair of keys is generated.

3.2 The RSA algorithm: Description of the Algorithm, Computational aspects, Security of RSA.

✓ **RSA algorithm** is an asymmetric cryptography algorithm. Asymmetric actually means that it works on two different keys i.e. **Public Key** and **Private Key.**
✓ RSA is the most common public-key algorithm, named after its inventors Rivest, Shamir, and Adelman (RSA).



RSA

RSA algorithm uses the following procedure to generate public and private keys:

✓ Select two large prime numbers, p and q.
✓ Multiply these numbers to find **n = p x q**, where n is called the modulus for encryption and decryption.
✓ Choose a number e less than n, such that n is relatively prime to **(p - 1) x (q -1).** It means that e and (p - 1) x (q - 1) have no common factor except 1.
✓ If **n = p x q**, then the public key is <e, n>.
✓ A plaintext message m is encrypted using public key <e, n>. To find ciphertext from the plain text following formula is used to get ciphertext C.
$C = m^e \bmod n$
✓ To determine the private key, we use the following formula to calculate the d such that:
$D_e \bmod \{(p - 1) \times (q - 1)\} = 1$

- ✓ The private key is <d, n>.
- ✓ A ciphertext message c is decrypted using private key <d, n>. To calculate plain text m from the ciphertext c following formula is used to get plain text m.

  $m = c^d \bmod n$

Advantages of RSA

Key Sharing: RSA encryption depends on using the receiver's public key, so you don't have to share any secret key to receive messages from others.

Proof of Authenticity: Since the key pairs are related to each other, a receiver can't intercept the message since they won't have the correct private key to decrypt the information.

Faster Encryption: The encryption process is faster than that of the DSA algorithm.

Data Can't Be Modified: Data will be tamper-proof in transit since meddling with the data will alter the usage of the keys. And the private key won't be able to decrypt the information, hence alerting the receiver of manipulation.

Security of RSA:-
These are explained as following below.

1. Plain text attacks:
It is classified into 3 subcategories:-

- **Short message attack:**
  In this we assume that attacker knows some blocks of plain text and tries to decode cipher text with the help of that. So, to prevent this pad the plain text before encrypting.
- **Cycling attack:**
  In this attack, the attacker thinks that the cipher text has been generated by using some permutation. He uses all possible permutations of plain text to decipher the cipher text by 'cycling' the permutations.
- **Unconcealed Message attack:**
  Sometimes it happens that plain text is same as cipher text after encryption. So it must be checked or it will be of no use as the attacker will see right through it.

2. Chosen cipher attack:
In this attacker is able to find out plain text based on cipher text using the Extended Euclidean Algorithm.

3. Factorization attack:
If the attacker is able to know P and Q using N, then he can find out value of private key. This fails when N contains at least 300 longer digits in decimal terms, attacker will not able to find it. Hence this is infeasible for larger numbers.

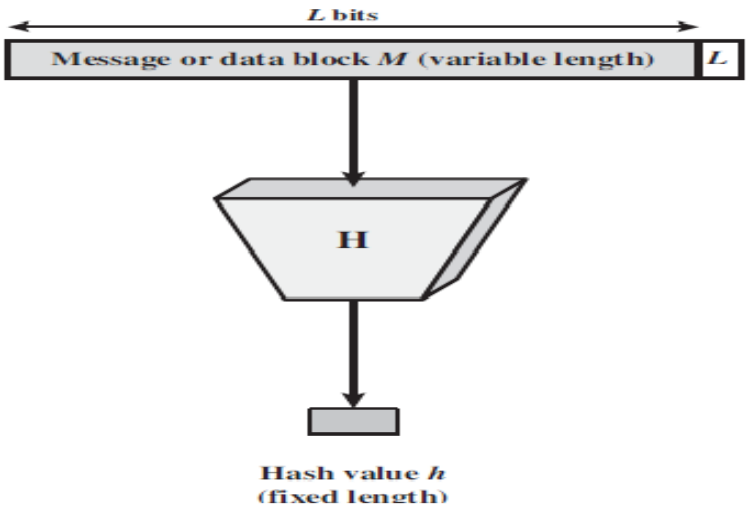
4. Attacks on Encryption key:
People well versed with the mathematics of RSA sometimes feel that it is quite easy because it can

VPMP POLYTECHNIC

need a huge number for the public key or encryption key E. It also creates RSA more secure. Therefore, if it can decide to try and create the working of RSA faster by utilizing a small value for E, it can lead to potential attacks known as attacks on the encryption key and therefore it is suggested that it can use E as 216 + 1 = 65537 or a value nearer to this number.

Hash function

- ✓ A hash function is a mathematical function that converts a numerical input value into another compressed numerical value.
- ✓ The input to the hash function is of arbitrary length but output is always of fixed length.
- ✓ Values returned by a hash function are called message digest or simply hash values.
- ✓ Example: Secure Hash Algorithm



- ✓ Hash function H accepts a variable length block of data M as input and produces fixed sized hash value h=H(M).
- ✓ It is impossible to recreate the input data from its hash value.
- ✓ Input is called the **Message**.
- ✓ Hash value is called the **Message Digest**.
- ✓ It is infeasible to find two different messages with the same hash.

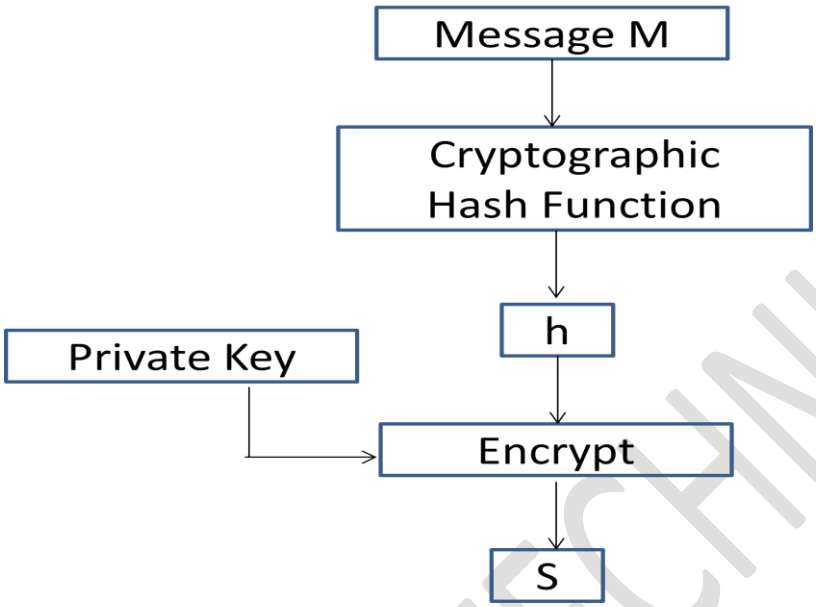
❖ **Digital signatures**

- ✓ It is a method that enables the creator of message to attach a code that act as a signature.
- ✓ When there is not complete trust between sender and receiver, Digital Signature is needed.
- ✓ Digital Signature is an electronic signature that can be used to authenticate the identity of the sender of a message and ensure that content of the message that has been sent is unchanged.

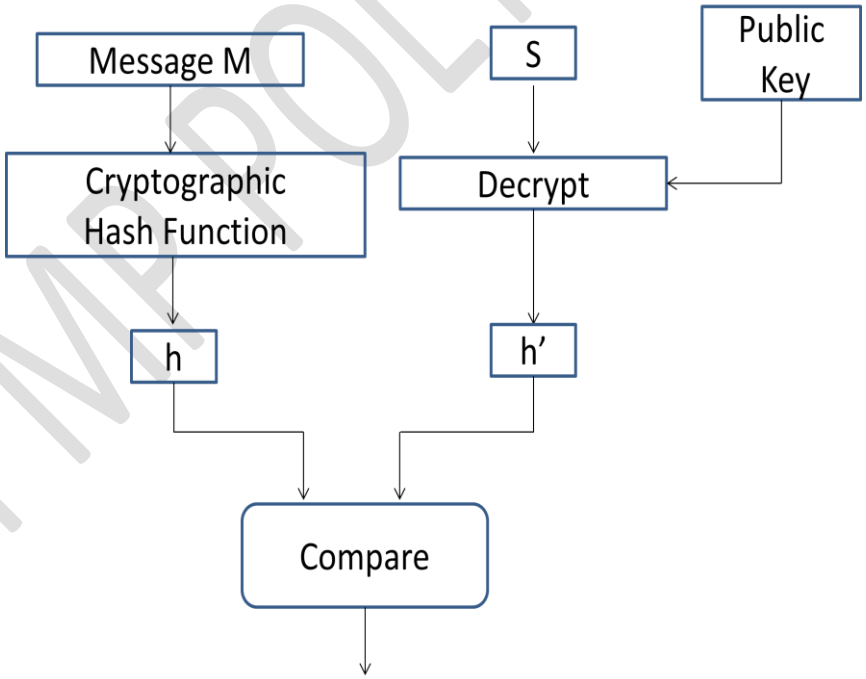
Property of Digital Signature:

- ✓ It must verify the sender, date and time of signature.
- ✓ It must authenticate the content at the time of signature.

- ✓ It must be verifiable by third parties to resolve disputes.



Signature for M (Sender Side)



(Receiver Side)

VPMP POLYTECHNIC

- ✓ Digital signature give two algorithm: one for sender which involve the user's private key and one for verifying signature which involve user's public key.

steps for creating digital signature:

- ✓ It involves two processes, one performed by the sender and other by the receiver.
- ✓ To create a Digital Signature, Hash function is used and using private key, it is encrypted.
- ✓ At receiver site, verification process is done.
- ✓ For that, Hash value is generated from message and signature is decrypted using public key. Then compare both to check it is valid or not.

Digital Signature consists of 3 algorithms:

1. **A key generation algorithm:** it chooses private key randomly and generate public key.
2. **A signature assigning algorithm:** using private key it generates signature to a message.
3. **A signature verifying algorithm:** using public key and signature message will be verified.

Digital signature services:

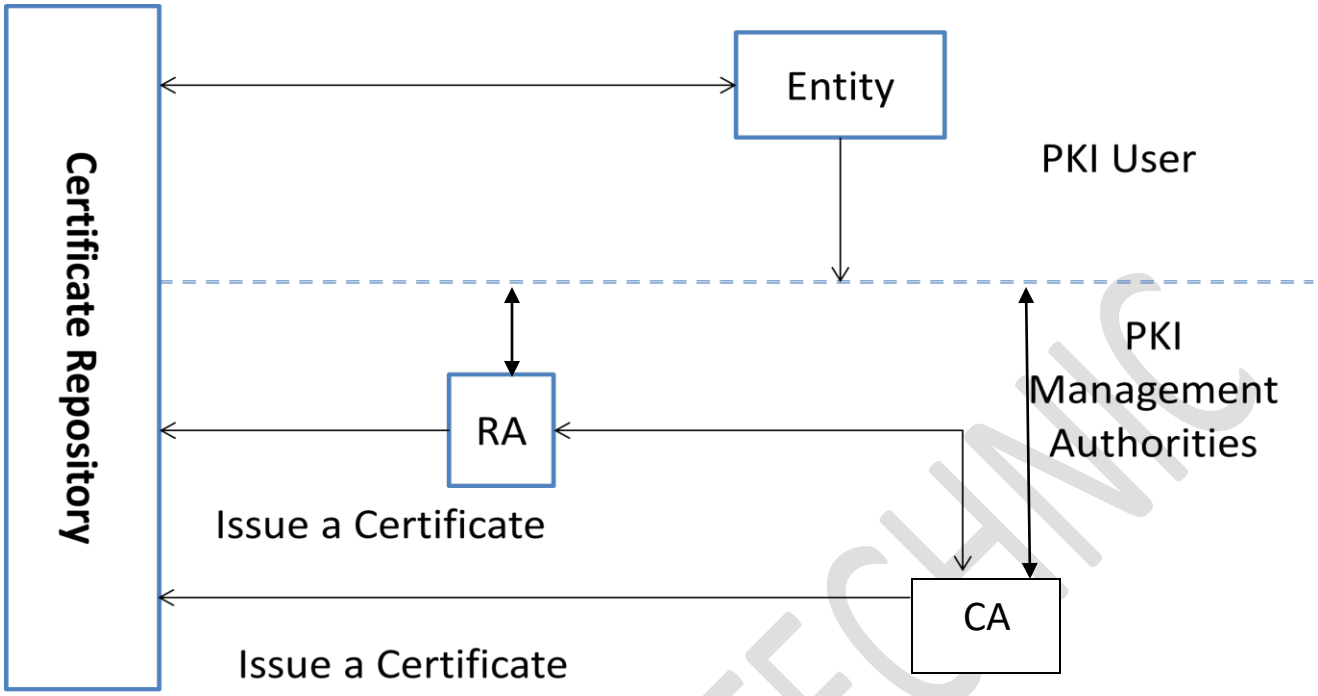
1. Message authentication: Provide authentication about sender.
2. Message integrity: Message is received same as it was sent.
3. Non repudiation: Preventing sender from denying that he/she does not sent a message

❖ **PKI (public key infrastructure)**

- ✓ PKI is also called asymmetric key Infrastructure, uses a key pair to encrypt and decrypt the data.
- ✓ A PKI enables users of a unsecure to securely and privately exchange data through the use of a private and public cryptography.
- ✓ The Key pair is consists of a private and public key.
- ✓ The Private key must be kept secret.
- ✓ Public key needs to be distributed.
- ✓ Data encrypted by one of the two keys can be decrypted by the other.
- ✓ The key problem of PKI is to manage the public keys.
- ✓ Currently, PKI uses Digital Certificate mechanism to solve the problem.
- ✓ Digital Certificate binds public key to their owners, help to distribute public keys in large network securely.

Architecture of PKI

VPMP POLYTECHNIC



Entity: End user of PKI services, such as person, an organization, a device like a router.

Certificate Authority: CA uses certificates specifies the validity periods of certificate.

Registration Authority: RA implements functions like identity authentication, Key pair generation and key pair backup.

PKI Repository: Server or common database. It stores and manages information like certificate request, certificates, keys. From LDAP server, an entity can retrieve local and CA certificates.

❖ **Digital certificate**

- Digital Certificate is a file signed by a CA for an entity.
- It includes identity information of the entity, Public key of the entity, name and signature of CA, validity period of the certificate where the signature of CA ensures the validity and authority of the certificate.
- Digital Certificate binds a public key to information about its owner.
- Two types of certificate: Local and CA certificate.
- Local Certificate is a digital certificate signed by CA for entity.
- CA certificate is a certificate of a CA .
- Digital Certificate are issued by CA.
- CA is made of software, hardware, policies, policies and people.

Steps for obtaining Digital Certificate

1. When a user requests a certificate, the registration process will require the user to enter specific information in to a web form.

VPMP POLYTECHNIC

2. The web page accepts the user's public key or it will step the user to create a public/private key pair, which allow user to choose the size of the keys to be created.
3. Then public key and registration form are forwarded to the RA for processing.RA is responsible only for registration process and cannot actually generate a certificate.
4. Once the RA is finished processing the request and verify the individual's identity , the RA sends request to the CA.
5. The CA uses the RA – provided information to generate a digital certificate and integrates necessary data into the certificate and send a copy of the certificate to the user.

steps for verifying authenticity and integrity of a certificate

✓ Certificate authorities verify digital certificates by checking the certificate's signature using the issuer's public key.
✓ The process of verification involves a series of steps that ensure the authenticity and integrity of the digital certificate.
✓ The CA checks the digital signature on the certificate. This signature is created by the issuer of the certificate using their private key.
✓ The CA uses the issuer's public key to decrypt the signature. If the decrypted signature matches the certificate's data, it confirms that the certificate is indeed issued by the claimed issuer and has not been tampered with.
✓ The CA verifies the certificate's validity period. Every digital certificate has a specific period during which it is considered valid. If the current date falls within this period, the certificate is deemed valid.
✓ The CA also checks the certificate revocation list (CRL). This is a list of certificates that have been revoked by the issuer before their scheduled expiry date due to various reasons such as compromise of the private key. If the certificate is found on this list, it is considered invalid.
✓ The CA verifies the certificate's usage. Certificates are issued for specific purposes, such as server authentication, client authentication, or code signing.
✓ The CA checks whether the certificate is being used for its intended purpose.
✓ The CA checks the certificate's binding. A digital certificate binds a public key to the entity that holds the corresponding private key. The CA verifies this binding to ensure that the entity presenting the certificate is the actual owner of the public key.
✓ The verification of digital certificates by a CA involves checking the certificate's signature, validity period, revocation status, usage, and binding. This process ensures the authenticity, integrity, and trustworthiness of the digital certificate and the entity it represents.